

Droit du numérique, automate Picard

Haider Rayan Boudjemeline, B3 IIM, rattrapage

Objectif

Picard veut poser des automates réfrigérés dans des campus. On choisit un produit sur l'écran, on paie par carte, le casier s'ouvre. La borne propose aussi de créer un compte fidélité, donc elle récupère au moins un mail ou un numéro, plus l'historique de ce qu'on achète dessus. J'ai pris le sujet comme une check-list de ce que je regarderais avant de valider l'installation.

Le compte fidélité et le RGPD

Le compte fidélité est la première chose qui saute aux yeux sur cet automate, Lorsque Picard demande un mail ou un numéro pour créer le compte, ça confirme bien qu'on est dans le RGPD. Donc nous sommes bien dans la légalité pour les données collectées (le contrat pour le compte, le consentement si on veut envoyer des promos), une durée de conservation fixée à l'avance, notifiée et respectée, et un moyen simple pour l'utilisateur de supprimer son compte. Sur une borne dans un couloir d'école, je vois mal quelqu'un lire une politique de confidentialité de 6 pages sur un écran tactile, donc il faut une version courte affichée avant la création du compte et un QR code vers la version complète. La CNIL a déjà sanctionné Carrefour de 2,25 millions d'euros en 2020, en partie sur les durées de conservation.

Le compte doit collecter le minimum, un mail suffit. Sur picard.fr la politique de confidentialité parle de 25 mois de conservation après le dernier contact pour le programme fidélité, la borne doit reprendre la même règle et avoir sa ligne dans le registre des traitements vu que c'est un nouveau point de collecte. Il faut aussi des CGU acceptées avec une vraie case à cocher et garder la preuve du clic, sinon Picard ne peut rien prouver si un étudiant conteste plus tard.

Le mail doit être confirmé par un lien avant que le compte soit actif. Sans ça n'importe qui crée un compte avec l'adresse d'un ami par exemple pour lui faire recevoir des promos. Ce serait de l'usurpation d'identité, l'article 226-4-1 du code pénal va jusqu'à un an de prison et 15 000 euros. Après il y a les sous-traitants, l'exploitant de la machine, la société de paiement, l'hébergeur des comptes. Chacun signe un contrat article 28 qui dit ce qu'il a le droit de faire avec les données. Picard a déjà un DPO, son adresse est sur le site, c'est lui qui valide tout ça.

La chose en plus par rapport à un site web c'est que la machine est physique, dans un lieu public. La session doit se fermer toute seule si l'étudiant part sans se déconnecter, et quelqu'un qui force la porte ne doit pas repartir avec une base de données. Sur un campus il y a aussi des mineurs. Le consentement d'un mineur pour un service en ligne n'est valable seul qu'à partir de 15 ans en France, donc une case "j'ai plus de 15 ans" et pas de marketing ciblé sur ce public, sinon on part sur une analyse d'impact.

Vente

Un achat sur une borne n'est pas une vente à distance, le code de la consommation met les distributeurs automatiques à part. Il n'y a donc pas de droit de rétractation, ce qui tombe bien pour du surgelé qui ne peut pas être repris une fois sorti du casier. Le reste du code de la consommation s'applique, les prix en euros TTC affichés avant l'achat avec le prix au kilo, et les CGV lisibles sur la borne, pas juste un lien vers le site. Un prix pas affiché c'est jusqu'à 15 000 euros d'amende pour une société.

Pour les allergènes, le règlement INCO exempte les distributeurs automatiques, l'emballage suffit. Je les mettrais à l'écran quand même, un étudiant allergique ne peut pas lire le sachet avant d'avoir payé. Le surgelé doit rester à -18 °C, donc la borne a besoin d'une sonde et d'une coupure des ventes si ça remonte. Et il faut un vrai service client. Il m'est déjà arrivé de perdre 2 euros dans un distributeur sans aucun numéro à appeler, donc au minimum une adresse de réclamation sur la façade et un reçu par mail.

Si l'écran charge son catalogue depuis un serveur, la LCEN demande les mentions légales classiques, raison sociale, adresse, hébergeur. Côté paiement, Picard ne stocke jamais de numéro de carte, c'est le terminal certifié et la société de paiement qui gèrent ça.

Ce qui peut mal tourner

Le risque le plus sérieux c'est une fuite des données du compte, mails, téléphones et heures de passage de milliers d'étudiants, avec la notification à la CNIL sous 72 heures. Ensuite il y a le côté physique. Une borne dans un couloir se fait vandaliser, et un lecteur de carte accessible à tous peut recevoir un skimmer. Une panne de froid une nuit et le lendemain on vend du décongelé recongelé, avec un rappel produit derrière. Et le litige avec l'école, qui paie si la borne fait un dégât des eaux. Le contrat de concession de l'université Lyon 2 pour ses distributeurs met tout sur l'exploitant, maintenance et assurances, avec une redevance d'au moins 15 % du chiffre d'affaires, Picard doit s'attendre au même genre de convention.

Le contrôle

La CNIL est chargée du contrôle des données personnelles. En 2025 elle a rendu 83 sanctions pour 486,8 millions d'euros. Le cas qui ressemble le plus au sujet c'est 3,5 millions en décembre 2025 contre une enseigne qui envoyait les mails de son programme fidélité à un réseau social pour de la pub, sans le dire sur le formulaire. Pour les prix, les CGV et la sécurité des aliments c'est la DGCCRF et ses services départementaux, la DDPP a mis 20 000 euros à un Carrefour Market de Villeurbanne pour des prix pas affichés. Au final la même borne peut recevoir une visite de la DDPP pour le froid et un contrôle CNIL pour le compte, avec des montants qui n'ont rien à voir.